

Executive Security Scan Report — Scan #35

Target Endpoint:	http://localhost:3000	Scan Status:	COMPLETED
Execution Date:	2026-08-29 19:06:54	Composite Vector Score:	100.0 / 100 (CRITICAL)

Vulnerability Severity Breakdown

Severity Level	Discovered Count	CISA KEV Exploited	Max EPSS Score
CRITICAL	1	No	0.0
HIGH	2	No	0.0
MEDIUM	1	No	0.0
LOW / INFO	6	No	0.001

Detailed Findings & Threat Intelligence

ID	Check Name / Title	Severity	CISA KEV / EPSS	Remediation Summary
#324	Missing Security Header: Strict-Transport-Security	LOW	Standard EPSS: N/A	Enforce HTTPS by sending the Strict-Transport-Security header with a long max-age and includeSubDomains directive....
#325	Missing Security Header: Content-Security-Policy	MEDIUM	Standard EPSS: N/A	Add the Content-Security-Policy HTTP header to restrict approved sources of content and mitigate XSS and data injection ...
#326	Missing Security Header: Referrer-Policy	INFO	Standard EPSS: N/A	Set Referrer-Policy header to control how much referrer information is included with requests....
#327	Exposed API Documentation	INFO	Standard EPSS: N/A	Restrict public web server access to interactive API documentation (Swagger/OpenAPI) in production environments via auth...
#328	Exposed Swagger UI	INFO	Standard EPSS: N/A	Restrict public web server access to interactive API documentation (Swagger/OpenAPI) in production environments via auth...
#329	Exposed FTP Directory	LOW	Standard EPSS: N/A	Disable anonymous FTP login and enforce secure encrypted protocols (SFTP/SSH) with strict firewall IP whitelist access c...
#330	Exposed Git Repository	HIGH	Standard EPSS: N/A	Remove or restrict public web server access to the '.git/' version control directory to prevent source code exposure....
#331	Exposed Metrics Endpoint	LOW	Standard EPSS: N/A	Protect application performance metrics (/metrics) behind HTTP basic authentication or bind metrics exporters to private...

CONFIDENTIALITY NOTICE: This report is generated locally by NKAT Sentinel Console. All scan findings, threat scores, and target metadata remain 100% strictly on localhost. Target endpoint authorization strictly validated against docs/AUTHORIZED_TARGETS.md policy.